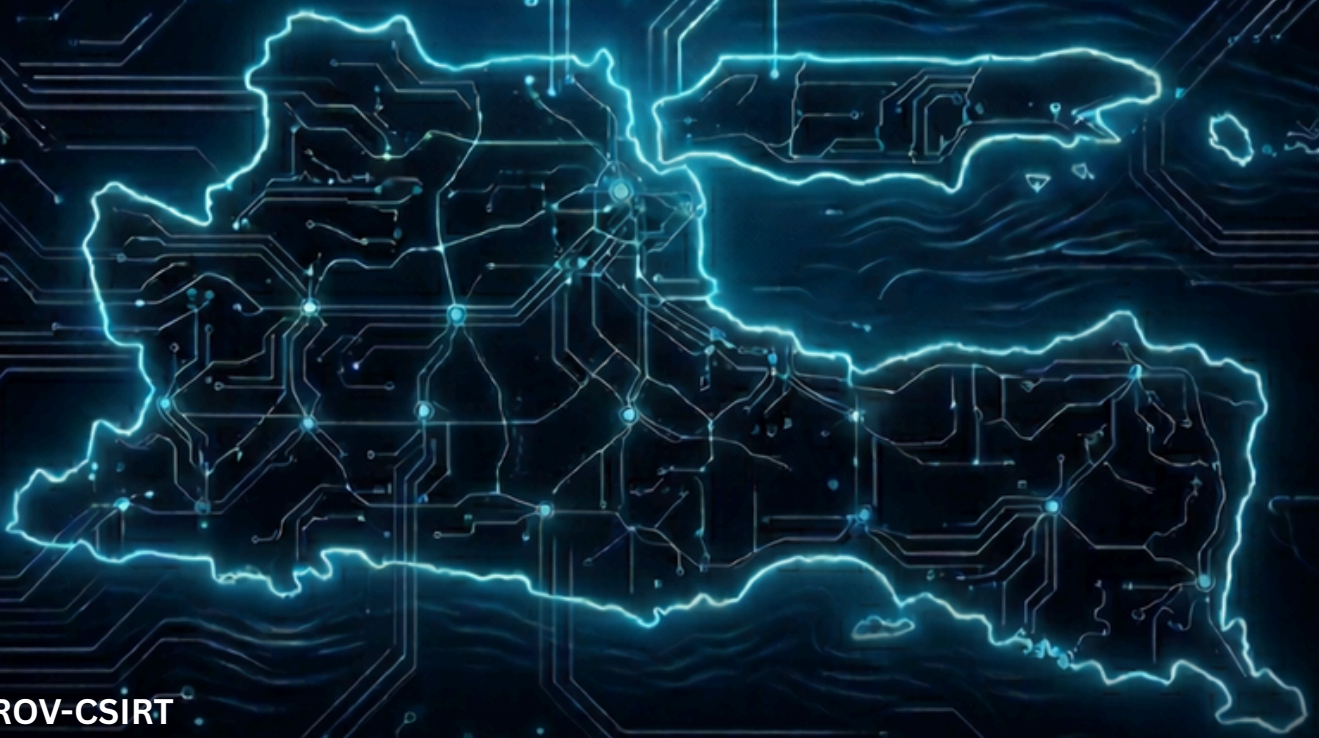




TOP 5 KERENTANAN PADA DOMAIN JATIMPROV.GO.ID

2025



SAMBUTAN KEPALA DINAS KOMUNIKASI DAN INFORMATIKA PROVINSI JAWA TIMUR



**Sherlita Ratna Dewi
Agustin, S.Si., M.IP.**



Kominfo Jatim mendorong seluruh Perangkat Daerah Provinsi Jawa Timur agar memastikan penggunaan domain jatimprov.go.id dilakukan secara benar dan aman, melalui tahapan pengujian keamanan atau *IT Security Assessment* (ITSA) sebelum dioperasikan.

Di tengah era transformasi digital yang masif, Pemerintah Provinsi Jawa Timur terus berkomitmen untuk menghadirkan layanan publik yang transparan, cepat, dan berbasis teknologi, terutama melalui optimalisasi domain utama jatimprov.go.id. Namun, kami menyadari bahwa seiring dengan meningkatnya ketergantungan pada infrastruktur digital, risiko serangan siber juga mengalami eskalasi yang signifikan. Bagi kami, keamanan siber bukan lagi sekadar aspek teknis tambahan, melainkan pilar utama dalam menjaga integritas data pemerintah dan merawat kepercayaan masyarakat Jawa Timur.

Sepanjang tahun 2025, lanskap ancaman siber menunjukkan dinamika yang kompleks. Berbagai upaya peretasan mulai dari eksploitasi celah perangkat lunak hingga serangan berbasis manipulasi data telah menargetkan aset digital pemerintah. Fenomena ini menuntut kita untuk tidak hanya reaktif, tetapi juga proaktif. Laporan ini disusun sebagai bentuk evaluasi mendalam terhadap titik-titik lemah (*vulnerabilities*) yang paling sering muncul, yang menjadi langkah krusial bagi kita untuk memperkuat pertahanan siber di masa mendatang.

Harapan kami, dokumen ini tidak hanya berhenti sebagai catatan statistik, melainkan menjadi pedoman strategis bagi seluruh Perangkat Daerah di Pemerintah Provinsi Jawa Timur dalam memitigasi risiko. Sinergi dan kolaborasi antar instansi adalah kunci utama untuk mewujudkan ekosistem digital yang tangguh dan aman bagi seluruh warga.

Kepala Dinas Komunikasi dan Informatika,



Ditanda tangani secara elektronik oleh

SHERLITA R. D. A., S.Si., M.IP.

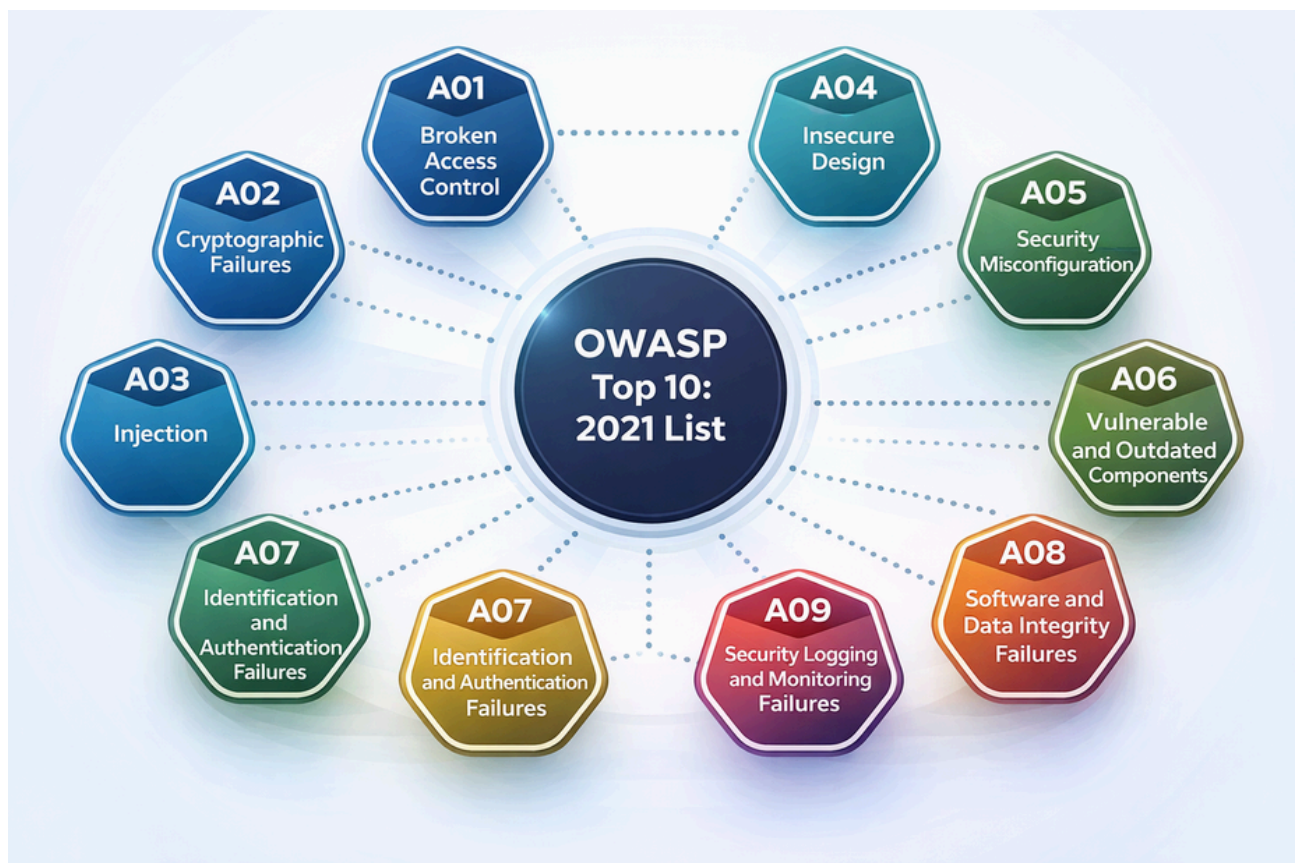
NIP 197508051998032002

SHERLITA R. D. A., S.Si., M.IP.
Pembina Utama Muda (IV/c)
NIP 197508051998032002

DAFTAR ISI

4	OWASP TOP 10:2021
5	HIGHLIGHT ITSA 2025
6	TOP 5 KERENTANAN
6	A01: BROKEN ACCESS CONTROL
7	A07: IDENTIFICATION AND AUTHENTICATION FAILURES
8	A05: SECURITY MISCONFIGURATION
9	A04: INSECURE DESIGN
10	A03 - INJECTION

Disusun oleh:
Bidang Persandian dan Keamanan Informasi
Dinas Komunikasi dan Informatika Provinsi Jawa Timur



OWASP TOP 10: 2021

Standar daftar risiko keamanan aplikasi web

OWASP Top 10: 2021 merupakan standar kesadaran keamanan aplikasi *web* yang berfokus pada sepuluh risiko paling kritis dalam ekosistem perangkat lunak modern. Daftar ini dipimpin oleh *Broken Access Control*, di mana kegagalan pembatasan akses memungkinkan pengguna yang tidak sah masuk ke area terlarang, diikuti oleh *Cryptographic Failures* yang menekankan pada kegagalan perlindungan data sensitif akibat algoritma yang lemah atau pengelolaan kunci yang buruk. Kerentanan klasik seperti *Injection* tetap menjadi ancaman besar, sementara kategori baru seperti *Insecure Design* menyoroti pentingnya keamanan sejak tahap perancangan awal, bukan hanya pada penulisan kode.

Selain itu, aspek operasional juga menjadi perhatian serius melalui *Security Misconfiguration*, penggunaan *Vulnerable and Outdated Components*, serta Identification and Authentication Failures yang memicu kerentanan pada sistem login. Integritas sistem pun diperketat dalam kategori *Software and Data Integrity Failures*, yang berdampak pada keamanan pembaruan perangkat lunak. Daftar ini ditutup dengan *Security Logging and Monitoring Failures* yang menyoroti lambatnya deteksi serangan, serta *Server-Side Request Forgery (SSRF)* yang memungkinkan penyerang mengeksploitasi server internal melalui aplikasi web yang terpercaya.

HIGHLIGHT ITSA 2025

27

APLIKASI

22

PERANGKAT DAERAH

88

KERENTANAN

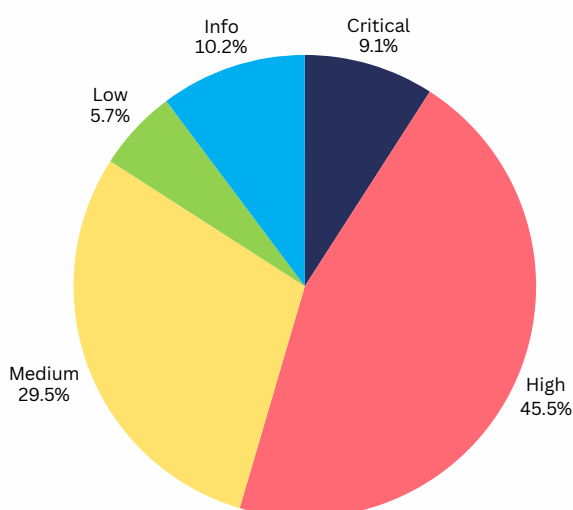
IT Security Assessment (ITSA) merupakan salah satu layanan pengujian kerentanan pada sistem elektronik yang diberikan oleh Dinas Komunikasi dan Informatika Provinsi Jawa Timur, khususnya untuk sistem elektronik berdomain jatimprov.go.id. Untuk setiap sistem elektronik yang akan menggunakan domain jatimprov.go.id akan melalui fase pengujian kerentanan.

Pada tahun 2025 telah dilakukan ITSA pada 27 aplikasi dari 22 Perangkat Daerah Provinsi Jawa Timur. Dari pengujian tersebut, berhasil diidentifikasi 88 celah kerentanan yang terdiri dari 8 kerentanan *critical*, 40 kerentanan *high*, 26 kerentanan *medium*, 5 kerentanan *low* dan 9 kerentanan *info*.

Berdasarkan standar OWASP Top 10:2021, pemetaan celah keamanan menunjukkan bahwa *A01: Broken Access Control* merupakan kerentanan terbanyak dengan 24 temuan. Kerentanan selanjutnya diikuti oleh *A07: Identification and Authentication Failures* sebanyak 20 temuan, *A05: Security Misconfiguration* sebanyak 19 temuan, *A04: Insecure Design* sebanyak 15 temuan, serta *A03: Injection* dengan 9 temuan.

GRAFIK TINGKAT RISIKO

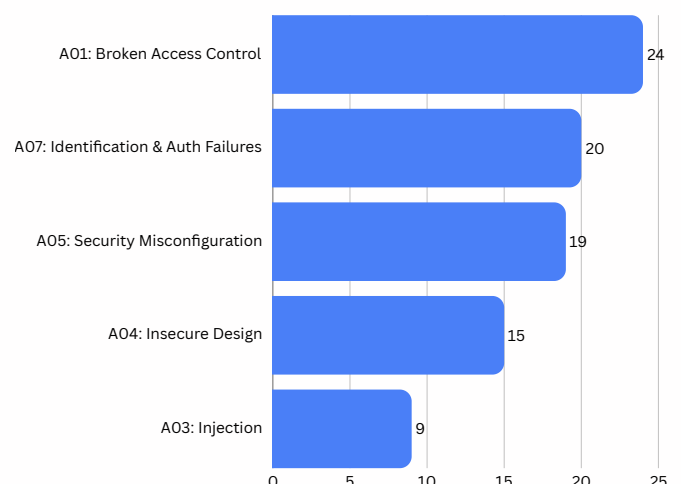
Tahun 2025



Temuan celah kerentanan berdasarkan tingkat risiko (*risk severity*) yaitu *Critical*, *High*, *Medium*, *Low* dan *Info*.

TOP 5 CELAH KERENTANAN

Tahun 2025



Pemetaan celah kerentanan berdasarkan standar OWASP Top 10:2021

TOP 5 KERENTANAN

1. A01: Broken Access Control

Broken Access Control memungkinkan pengguna reguler untuk melewati kebijakan keamanan yang ditetapkan, sehingga mereka berpotensi mengakses fungsi administratif, memanipulasi data yang tidak berhak mereka lihat, atau mengekspos informasi sensitif milik pengguna lain. Skenario eksploitasi yang paling umum ditemukan meliputi *Insecure Direct Object Reference* (IDOR) dan eskalasi hak istimewa (*privilege escalation*)



Privilege Escalation

Privilege Escalation adalah celah fatal di mana pengguna biasa memanipulasi sistem untuk mendapatkan hak akses tingkat administrator. Penyerang mengeksplotasi kerentanan otorisasi ini untuk mengambil alih kendali aplikasi, mengubah konfigurasi kritis, hingga mencuri seluruh data sensitif tanpa batasan.

Untuk mencegahnya, terapkan prinsip Least Privilege dengan memberikan hak akses seminimal mungkin. Wajibkan validasi peran *Role-Based Access Control* secara mutlak di sisi server pada setiap permintaan, dan jangan pernah mempercayakan parameter hak akses di sisi klien.

Insecure Direct Object Reference

Insecure Direct Object Reference (IDOR) adalah celah kritis di mana aplikasi mengekspos ID data internal (seperti nomor rekam medis atau data pegawai) tanpa validasi. Penyerang dapat memanipulasi ID di URL untuk mencuri atau mengubah data rahasia milik pengguna lain secara ilegal.

Untuk remediasi, terapkan *Object-Level Access Control* untuk memverifikasi kepemilikan data pada setiap akses. Ganti ID berurutan dengan pengenal acak (UUID) dan gunakan referensi tidak langsung melalui token sesi agar ID asli tidak terekspos ke publik.



“The only safe password is one you can’t remember.”

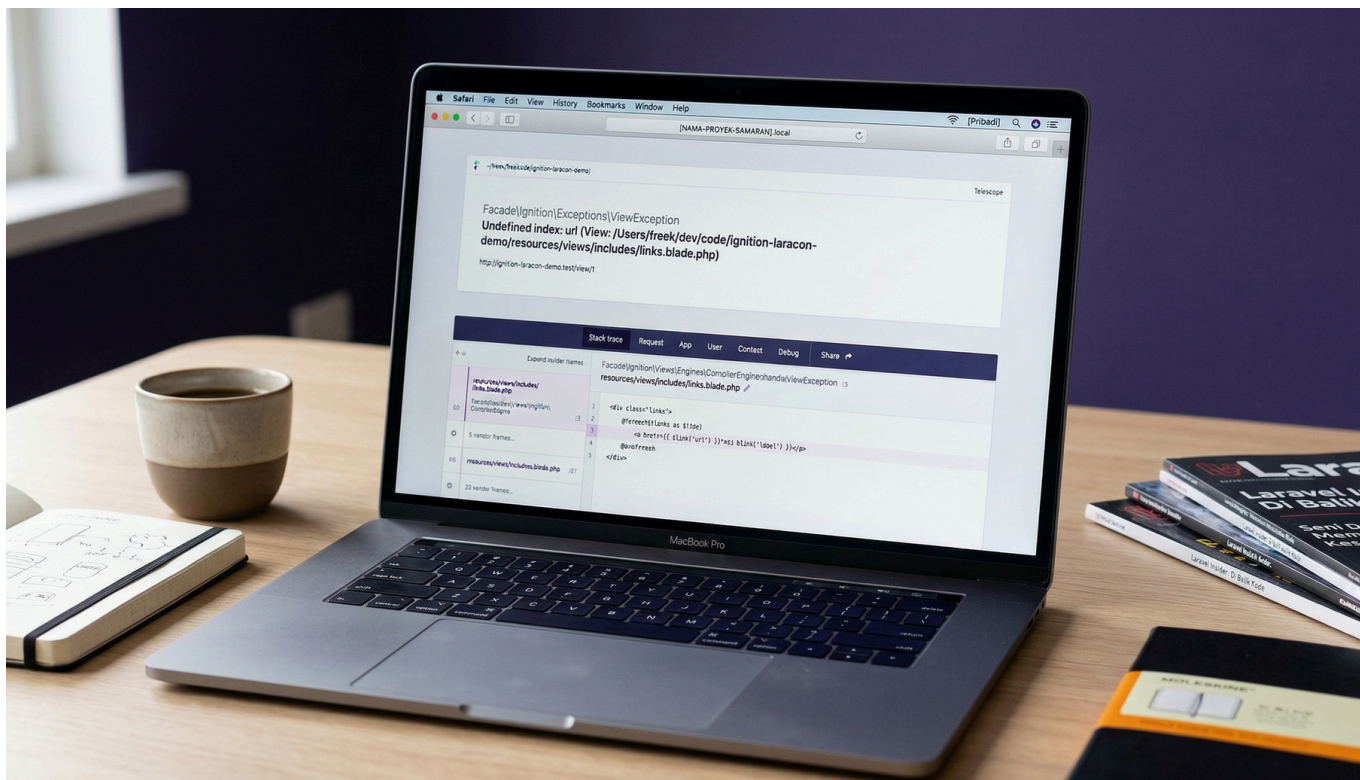
2. A07: Identification and Authentication Failures

Identification and Authentication Failures adalah celah keamanan yang terjadi ketika mekanisme sistem login dan manajemen sesi tidak diimplementasikan dengan benar. Penyerang mengeksploitasi kelemahan ini untuk mencuri kata sandi, membajak token sesi, dan mengambil alih identitas pengguna yang sah secara penuh. Salah satu kerentanan yang sering diidentifikasi yaitu *Weak Password Policy*.

Weak Password Policy

Weak Password Policy (Kebijakan Sandi Lemah) adalah celah krusial di mana sistem mengizinkan pembuatan kata sandi yang pendek dan mudah ditebak. Kelemahan ini sangat rentan dieksploitasi oleh penyerang melalui serangan brute-force atau tebakan kamus untuk mengambil alih akun secara paksa.

Sebagai langkah mitigasi, wajibkan standar sandi yang kuat (minimal 8 karakter, kombinasi huruf, angka, dan simbol). Terapkan juga Autentikasi Multi-Faktor (MFA), blokir kata sandi yang umum digunakan, serta batasi jumlah percobaan login gagal untuk menghentikan serangan tebakan otomatis.



3. A05: Security Misconfiguration

Security Misconfiguration adalah celah kerentanan yang bersumber dari kelemahan pada pengaturan infrastruktur, bukan dari cacat penulisan kode sumber aplikasi. Celah ini sering terbuka karena sistem menggunakan konfigurasi bawaan (*default*), layanan tidak esensial dibiarkan menyala, atau pengaturan environment yang tidak dioptimalkan untuk produksi. Dalam hasil asesmen ini, temuan paling menonjol adalah aktifnya fitur *Laravel Debug Mode* di server publik. Ketika mode ini aktif, aplikasi yang mengalami error akan menampilkan *stack trace* yang dapat membocorkan informasi sensitif seperti versi *framework*, struktur direktori, hingga kredensial database kepada pengaksesnya.

Sebagai langkah mitigasi utama, organisasi harus menerapkan pengerasan sistem (*hardening*) secara disiplin di seluruh lapisan infrastruktur. Tim teknis wajib memastikan semua mode pengembangan atau debugging telah dinonaktifkan secara permanen sebelum aplikasi dirilis ke publik. Selain itu, pastikan semua kata sandi bawaan telah diubah, matikan layanan yang tidak esensial, dan gunakan halaman error kustom agar sistem tidak pernah membocorkan detail teknis kepada pengguna akhir.

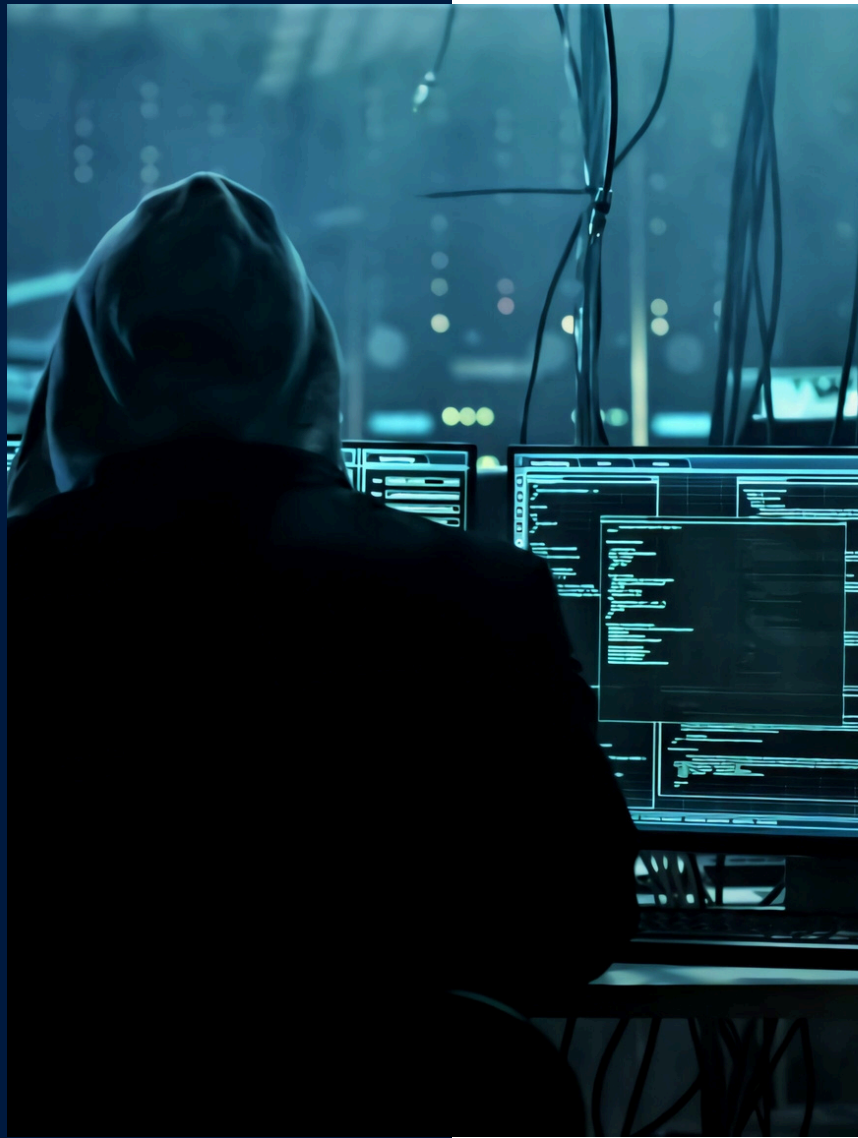
APP_DEBUG = false

4. A04: Insecure Design

Insecure Design adalah kategori kerentanan yang berakar pada cacat perancangan arsitektur aplikasi, bukan sekadar kesalahan penulisan kode (*coding error*). Kelemahan ini muncul ketika sistem tidak dibangun dengan memikirkan profil risiko atau pemodelan ancaman (*threat modeling*) sejak awal.

Unrestricted File Upload

Dalam asesmen ini, manifestasi paling kritis dari kelemahan desain tersebut adalah *Unrestricted File Upload* (Unggahan File Tanpa Batasan). Karena arsitektur aplikasi sejak awal tidak merancang mekanisme validasi file yang terpusat dan aman, fungsionalitas ini menjadi celah terbuka. Penyerang dapat mengeksploitasi cacat desain ini untuk mengunggah file eksekusi berbahaya (seperti skrip *backdoor* atau *malware*), yang berpotensi berujung pada pengambilalihan server secara penuh.



Sebagai langkah mitigasi yang mendasar, tim pengembang wajib mengadopsi prinsip Secure by Design dalam seluruh siklus hidup pengembangan perangkat lunak (SDLC). Khusus untuk meremediasi isu unggahan file, arsitektur sistem harus direvisi agar menerapkan *whitelist* tipe file secara ketat di sisi backend, mencabut hak eksekusi (*execute permission*) pada folder penyimpanan, dan idealnya memisahkan server media penyimpanan dari server aplikasi utama. Secara keseluruhan, setiap perancangan fitur baru wajib melalui evaluasi risiko keamanan untuk memastikan tidak ada celah logika sebelum kode mulai ditulis.

5. A03 - Injection

A03: Injection (Injeksi) adalah kerentanan yang terjadi ketika data yang tidak tepercaya dikirimkan ke dalam sebuah interpreter (penerjemah perintah) tanpa melalui proses validasi atau sanitasi yang memadai. Melalui celah ini, penyerang dapat memanipulasi input untuk mengeksekusi perintah tak sah, mencuri data sensitif pelanggan, hingga mengambil alih kendali aplikasi secara penuh. Dalam asesmen keamanan ini, varian injeksi yang paling dominan dan sangat berbahaya adalah Cross-Site Scripting (XSS) dan SQL Injection.



Cross-Site Scripting (XSS)

Cross-Site Scripting (XSS) adalah celah injeksi berbahaya yang terjadi ketika aplikasi web menampilkan masukan pengguna tanpa proses sanitasi yang memadai. Penyerang mengeksploitasi kelemahan ini dengan menyisipkan skrip jahat (seperti JavaScript) ke dalam halaman web yang sah. Saat halaman tersebut diakses, browser korban akan mengeksekusi skrip itu secara otomatis, memungkinkan penyerang untuk mencuri cookie sesi, mengambil alih akun, atau mengarahkan korban ke situs penipuan.

Sebagai langkah remediasi, pengembang dilarang keras mempercayai masukan apa pun dari luar. Aplikasi wajib menerapkan Context-Aware Output Encoding untuk mengonversi karakter khusus menjadi entitas HTML yang aman sebelum ditampilkan. Selain itu, terapkan Content Security Policy (CSP) guna memblokir eksekusi skrip asing.

SQL Injection

SQL Injection merupakan celah keamanan kritis yang terjadi ketika penyerang berhasil menyisipkan instruksi SQL berbahaya ke dalam form input atau URL. Karena aplikasi gagal memvalidasi data, sistem mengeksekusi input manipulatif tersebut sebagai perintah sah. Hal ini memungkinkan peretas membobol autentikasi, mencuri informasi rahasia, atau bahkan menghapus keseluruhan isi database.

Untuk remediasi permanen, tim pengembang wajib meninggalkan praktik perakitan kueri berbasis penggabungan string. Sangat diwajibkan untuk mengadopsi Prepared Statements (Parameterized Queries) atau teknologi ORM. Melalui metode ini, sistem akan memisahkan struktur kueri dari data input, sehingga masukan pengguna selalu diperlakukan sebagai teks biasa dan tidak bisa dieksekusi sebagai perintah jahat.



TOP 5 KERENTANAN PADA DOMAIN JATIMPROV.GO.ID

2025